

9.

CHANGES FROM V3.2.1

An overview of the major changes in the PCI DSS since the major previous version.



FUNDAMENTALS

FUNDAMENTALS CHANGES FROM v3.2.1

v4.0.0 of the PCI DSS bring some changes from previous versions. First, it's important to cover that most elements remain the same:

- We have the same goals (6), and the same requirements (12). Some requirements have been renamed, but they maintain the core purpose;
 - E.g., a requirement may have been renamed from “access to data” to “access to data and systems”, or from “firewall” to “network security mechanism”, in general;
- Sub-requirements are mostly the same. Some are reordered, grouped together, and we have new ones;
 - For example, new sub-requirements on returning visitor badges, protecting payment pages, etc;

FUNDAMENTALS

CHANGES FROM v3.2.1

One significant change is the renaming of requirements / sub-requirements to more general terms:

- For example, Requirement 1 was about firewalls in specific in v3.2.1, while in v4.0.0 it's about NSCs, or Network Security Controls in general. These could be firewalls, but also zero-trust architectures, next-generation firewalls, etc;
- You'll see many requirements and sub-requirements that mentioned specific technologies or systems, and that now use more general terms such as a "security mechanism", an "encryption protocol", or others;
- Another example is "commonly affected systems" in Req 5 (No Malware). Now, you just decide/justify the exceptions;
- But the core logic remains the same;





FUNDAMENTALS

FUNDAMENTALS CHANGES FROM v3.2.1

Then, another interesting change is the grouping of similar sub-requirements.

- For example, in certain requirements such as for Requirement 6 (“Develop Securely”), you would have several sub-requirements (one for explicitly coding security controls, another for protecting against all vulnerability types, another for having a proper software lifecycle, another for developer training, etc);
- Now, you have Sub-Requirement 6.2 (“Bespoke and custom software are developed securely”) with all of that included, and sub-sub-requirements within it;
- The same occurs for many requirements. Similar controls or operations have been “grouped” for simplicity;

FUNDAMENTALS

CHANGES FROM v3.2.1

Another relevant change is additions in sub-requirements:

- Most sub-requirements, as mentioned are the same, save for changes in terminology to make them more generic or encompass more use cases;
- But a significant addition is of new sub-requirements for common failure scenarios in the past that weren't explicit.
 - For example, in Req. 9 (Restrict Physical Access), it wasn't explicit visitors must return their badges (it is required, but was not explicit). This is now explicit;
 - In Req. 11 (Test Regularly), if segmenting the CDE network, it wasn't explicit that segmentation controls needed to be tested. This is now explicit;
- In short, new explicit sub-requirements for implicit actions;





FUNDAMENTALS

FUNDAMENTALS CHANGES FROM v3.2.1

Finally, v4.0.0 brings with it a customized approach to fulfilling most sub-requirements.

- v3.2.1 was already flexible on many sub-requirements. But now, in many cases, you can comply with a sub-requirement with entirely different controls, as long as they fulfill the purpose of the sub-requirement;
- For example, in Requirement 1 (“Keep a Firewall”), 1.2.5 states “All services, protocols, and ports allowed are identified, approved, and have a defined business need”
 - Its Customized Approach dictates: “Unauthorized network traffic (services, protocols, or packets destined for specific ports) cannot enter or leave the network”;

The same requirements can be met with different controls.

FUNDAMENTALS

CHANGES FROM v3.2.1

EXAMPLES

/01 “DOCUMENT + ENFORCE”

You may remember the sub-requirement, in every requirement, to document and enforce processes + policies. It's now reordered to be the first every time.

/02 BEST PRACTICES

Some specific points of sub-requirements are considered “Best Practices”. These don't have to be implemented until March 2025, unlike the rest.

/03 COMMON SENSE

A lot of requirements still have flexible periods (e.g. critical SW patches applied in 1 month, and all others at a “reasonable pace”). They still need a rationale.

FUNDAMENTALS

CHANGES FROM v3.2.1

KEY TAKEAWAYS

/01 A LOT STAYS THE SAME

A lot remains the same from v3.2.1. We have the same goals and requirements, and mostly the same sub-requirements, save for small changes.

/03 SIMILAR GROUPINGS

Similar sub-requirements have been grouped in v4.0.0. Instead of several sub-requirements for related objectives, one sub-requirement now includes all.

/03 A CUSTOMIZED APPROACH

While v.3.2.1 was flexible in implementing controls, v4.0.0 allows a Customized Approach for most - different, alternative ways to fulfill the same objective.

/02 SIGNIFICANT RENAMING

Several requirements and sub-requirements have been renamed to encompass more scenarios, more systems, more controls, but the core is the same.

/04 IMPLICIT REQUIREMENTS

v4.0.0 also makes explicit certain sub-requirements that were required, but weren't explicitly stated, such as visitors returning their badges upon leaving.